Bài thực hành 08

Kiểm thử Mờ: Hộp đen (Black-box) và Hộp trắng (White-box) Fuzzing

Hệ thống SecureSys – Kênh lệnh quản trị ẩn (ADMIN debug channel)

Học phần CSE703093 – An toàn phần mềm
Phenikaa University

Ngày 8 tháng 7 năm 2026

Tóm tắt nội dung

Bài thực hành cài đặt hai bộ fuzzer: **hộp đen** (đột biến ngẫu nhiên, không phản hồi) và **hộp trắng / coverage-guided** (dùng phản hồi độ phủ mã từ gcov để dẫn dắt tìm kiếm, mô phỏng đơn giản ý tưởng AFL), nhằm phát hiện một lỗi tràn bộ đệm ẩn sau một "kênh lệnh quản trị" (`ADMIN:` prefix) chỉ kích hoạt khi đầu vào khớp một mẫu (magic pattern) cụ thể.

Mục lục

1 Mục tiêu fuzzing: lỗi ẩn sâu **1**

2 Hai chiến lược fuzzing **2**

3 Kết quả so sánh (cùng ngân sách) **2**

4 Kết quả kiểm thử tự động **3**

5 Tài liệu tham khảo **3**

1 Mục tiêu fuzzing: lỗi ẩn sâu

`c/fuzz_target.c` chứa một backdoor debug: nếu dòng vào bắt đầu bằng `"ADMIN:"` và ký tự tiếp theo là `'X'`, phần còn lại được `strcpy()` vào bộ đệm 16 byte không kiểm tra độ dài (CWE-121). Điều kiện kích hoạt gồm 2 lớp nhánh lồng nhau – khó tiếp cận bằng fuzzing ngẫu nhiên thuần túy.

```c
if (strncmp(line, "ADMIN:", 6) == 0) {
    const char *payload = line + 6;
    if (payload[0] == 'X') {
        strcpy(cmd, payload);   /* CWE-121 neu strlen(payload) >= 16 */
    }
}
```

Listing 1: Lỗi ẩn (trích fuzz_target.c)

2 Hai chiến lược fuzzing

Chiến lược	Mô tả
Hộp đen	Đột biến ngẫu nhiên (chèn/xóa/thay ký tự, ghép token từ dictionary), **không** dùng phản hồi từ chương trình mục tiêu.
Hộp trắng (coverage-guided)	Sau mỗi lần chạy, đo tập dòng lệnh được thực thi (qua gcov, cô lập từng lần chạy). Nếu phát hiện dòng **mới**, giữ đầu vào đó lại để tiếp tục đột biến (ưu tiên LIFO – khai thác sâu ngay).

3 Kết quả so sánh (cùng ngân sách)

Fuzzer	Số lần thử	Số crash tìm được	Lần thử đầu tiên tìm cras
Hộp đen	1000	**0**	–
Hộp trắng (coverage-guided)	500	**3**	lần thứ 402

Log dấu vết khai phá của fuzzer hộp trắng cho thấy tiến trình từng bước:

```
Lan thu 1  : input='ORDEY:...' -> phu them nhanh ORDER/UNKNOWN
Lan thu 6  : input='ADMIN:he2llo' -> phu them nhanh ADMIN
Lan thu 399: input='ADMIN:Xhello' -> phu them nhanh ADMIN-X (dong strcpy)
Lan thu 402: input='ADMIN:XhelloQHZMOGFEYCZZUGPUR' -> CRASH (overflow)
```

Listing 2: Trích log fuzzer hộp trắng

Khi tăng ngân sách hộp đen lên 5000 lần thử (có hỗ trợ dictionary chứa token `"ADMIN:"`, `"X"`), fuzzer hộp đen **cũng có thể** tìm ra lỗi – chứng tỏ đây không phải giới hạn tuyệt đối, mà là **khoảng cách hiệu quả rất lớn** giữa hai chiến lược khi điều kiện kích hoạt có nhiều lớp nhánh.

4 Kết quả kiểm thử tự động

`tests/test_fuzzing.py` thực hiện 4 test, bao gồm điều kiện: fuzzer hộp trắng **phải** tìm được crash trong 500 lần thử, fuzzer hộp đen **không được** tìm thấy trong 1000 lần thử (với seed cố định để tái lập). **Kết quả: 4/4 test PASS.**

Mục tiêu học tạp

- Cài đặt fuzzer hộp đen và hộp trắng (coverage-guided).
- Đo lường định lượng hiệu quả tìm crash theo ngân sách.
- Hiểu vai trò của phản hồi coverage trong việc dẫn dắt tìm kiếm.
- Nhận diện rủi ro của ”kênh debug ẩn” (CWE-489) trong mã production.

Yêu cạu hoàn thiện

1. Log đầy đủ 2 fuzzer kèm số lần thử và crash tìm được.
2. Bảng so sánh công bằng (cùng ngân sách).
3. Kết quả thí nghiệm mở rộng ngân sách hộp đen và nhận xét.

Yêu cạu kẹt quạ

`tests/test_fuzzing.py` toàn bộ 4 test PASS; file crash được lưu lại kèm nội dung input gây lỗi trong thư mục `crashes/`.

5 Tài liệu tham khảo

- Đề cương CSE703093 – An toàn phần mềm, Chương 4 (4.5, 4.6).
- M. Zalewski, *American Fuzzy Lop (AFL) – Technical Whitepaper*.
- CWE-121, CWE-489 (Active Debug Code).